

Practica 2E – IDOR

SEGUNDA PARTE

Seguridad en el Desarrollo de Aplicaciones

Alumna: Luz Celeste López Rivera

Docente: Gerardo Ramírez Villareal

Objetivo

Analizar los riesgos asociados a la exposición de recursos mediante identificadores directos sin validar autenticación, autorización u ownership dentro de una aplicación web.

Desarrollo

Se creó un controlador API denominado `ApiController` con endpoints que permiten consultar información de usuarios mediante identificadores numéricos.

Los endpoints desarrollados fueron:

- GET /api/user/1
- GET /api/user/2
- GET /api/user/3
- GET /api/users

Las pruebas se realizaron desde el navegador consumiendo directamente los endpoints expuestos por la aplicación.

Durante las pruebas se observó que cualquier usuario puede modificar el identificador presente en la URL y acceder a la información de otros usuarios sin ningún tipo de validación o restricción.

Resultados obtenidos

Al entrar al endpoint `/api/user/{id}` fue posible obtener información correspondiente a distintos usuarios simplemente cambiando el valor del identificador, el endpoint `/api/users` permitió visualizar la totalidad de los registros almacenados en la base de datos.

Se observó la exposición de información sensible como nombres de usuario, correos electrónicos, balances y contraseñas.

Análisis del riesgo

La vulnerabilidad identificada corresponde a Insecure Direct Object Reference (IDOR), ya que la aplicación permite acceder a recursos utilizando identificadores directos sin verificar si el usuario tiene autorización para consultar dichos datos.

Esta vulnerabilidad puede permitir:

- Acceso no autorizado a información de terceros.
- Enumeración de usuarios mediante identificadores consecutivos.
- Exposición masiva de datos sensibles.
- Compromiso de credenciales almacenadas.
- Violación de la confidencialidad de la información.

El riesgo aumenta debido al uso de identificadores numéricos predecibles, lo que facilita la exploración automática de recursos por parte de un atacante.

Tabla de campos sensibles expuestos

Campo	Sensible	Riesgo
Id	No	Permite enumeración de usuarios
Username	Sí	Identificación de usuarios
Email	Sí	Exposición de datos personales
Balance	Sí	Exposición de información financiera
Password	Crítico	Compromiso de credenciales

Conclusión

La práctica permitió comprobar cómo la falta de controles de autorización puede provocar acceso indebido a información de otros usuarios. Mediante la simple modificación del identificador en la URL fue posible consultar registros que no deberían estar disponibles para cualquier usuario. Este tipo de vulnerabilidad representa un riesgo importante para la seguridad de las aplicaciones web y debe mitigarse implementando mecanismos de autenticación, autorización y validación de ownership sobre los recursos consultados.